

Reyco Marine — Proposed Security Hardening

Prepared: 2026-05-17 | **Prepared by:** GLV Dev Agent **Client:** Reyco Marine & Small Engine Ltd. | **Domain:** reycomarine.com **Hosting:** SiteGround GrowBig | **Stack:** WordPress + custom PHP theme + WooCommerce

> Note: Site is currently in staging at reyco.glvmarketing.ca. Live domain (reycomarine.com) transfer pending EPP code from DealerSpike. Hardening should be implemented on staging first and validated before cutover. PHP 7.4→8.x SiteGround cutover is May 20 — rollback runbook (Layer 5) is especially time-sensitive.

Layer 1 — Error Tracking & Logs

Current State

None. No Sentry or equivalent installed. PHP errors surface only in SiteGround error logs (not alerted). JS errors are invisible unless a user reports them. WP `WP_DEBUG` is off in production (correct), but there's no error aggregation layer.

Proposed Addition

Sentry Free tier (5,000 errors/month — sufficient for current traffic)

PHP side:

```
# In reyco-marine repo root
composer require sentry/sentry-sdk
```

```
// wp-config.php (above /* That's all, stop editing! */)
\Sentry\init(['dsn' => 'https://<key>@<org>.ingest.sentry.io/<project>']);
set_error_handler(function ($errno, $errstr, $errfile, $errline) {
    \Sentry\captureMessage("PHP Error [$errno]: $errstr in $errfile:$errline");
});
```

JS side (theme's functions.php):

```
wp_enqueue_script('sentry-js', 'https://browser.sentry-cdn.com/7.x.x/bundle.min.js', [],
wp_add_inline_script('sentry-js', 'Sentry.init({ dsn: "https://<key>@<org>.ingest.sentry
```

Alert config: Email alert on first occurrence of any new issue class → `amglvdigital@pm.me`. Slack webhook to `#internal-dev` for severity > warning.

Estimated effort	3h (Composer setup, WP integration, Sentry project creation, alert config, smoke test)
Risk to live site	None — read-only monitoring layer, no request path changes
Cost	\$0 (Sentry Free: 5k errors/mo, 14-day retention) — upgrade to \$26/mo if volume exceeds

Layer 2 — Rate Limiting

Current State

SiteGround GrowBig includes basic server-level brute force protection. No WP-layer rate limiting plugin installed. No Cloudflare proxy in front of `reycomarine.com` — direct SiteGround DNS. `/wp-login.php` and `/xmlrpc.php` are exposed at full request rate.

Proposed Addition

Two-part approach: WP plugin (immediate, zero-risk) + Cloudflare Free (optional, requires DNS change)

Part A — Limit Login Attempts Reloaded (WordPress plugin, no DNS change)

- Install via WP admin → Plugins → Add New: `Limit Login Attempts Reloaded`
- Config: 4 attempts → 20-minute lockout → 2 lockouts → 24-hour lockout
- Log lockouts to `wp-content/limit-login-attempts.log`
- Email alert to `amglvdigital@pm.me` on lockout

Part B — Cloudflare Free (optional, adds WAF + DDoS protection)

- Sign up at `cloudflare.com` (free)
- Add `reycomarine.com` zone, import existing DNS records
- Switch nameservers at registrar (15-min TTL drain)
- WAF rules to add:

```
# Rule 1: Block xmlrpc.php
(http.request.uri.path eq "/xmlrpc.php") → Block

# Rule 2: Rate limit wp-login.php (10 req/min per IP)
(http.request.uri.path eq "/wp-login.php") → Rate Limit: 10/60s → Block 10min

# Rule 3: Country challenge on non-CA/US wp-admin access
(http.request.uri.path contains "/wp-admin" and not ip.geoip.country in {"CA" "US"}) → Ma
```

Recommendation: Deploy Part A now (zero risk, Aiden WP admin). Schedule Part B for post-launch when domain is live (DNS change on live domain carries TTL risk if done wrong).

Estimated effort	0.5h (Part A only) / 2h (Part A + B including DNS change)
Risk to live site	Part A: Near-zero. Part B: Low-medium — DNS change has 15-min propagation window; if nameserver switch goes wrong, brief downtime possible. Test on staging first.
Cost	\$0 (Cloudflare Free, Limit Login Attempts Reloaded free)

Layer 3 — Uptime Monitoring

Current State

None. No automated monitoring. Downtime is detected only when Aiden or Casey manually visits the site or a customer complains.

Proposed Addition

UptimeRobot Free (50 monitors, 5-minute check interval)

Setup:

1. Create account at uptimerobot.com
2. Add monitors:
 - <https://reycomarine.com> — HTTP(S), 5-min interval
 - <https://reyco.glvmarketing.ca> — HTTP(S), 5-min interval (staging)
 - <https://crm.reycomarine.com> — HTTP(S), 5-min interval (Supabase CRM)
1. Alert contacts:
 - Email: amglvdigital@pm.me

- Slack webhook → #internal-dev
- Telegram webhook → boss agent (for after-hours pages)

1. Set alert threshold: down for 2 consecutive checks (10 min) before notify

SiteGround note: GrowBig includes basic uptime guarantee but no outbound alerts. UptimeRobot is the user-controlled layer.

Estimated effort	0.5h (all 3 monitors + alert config)
Risk to live site	None — external read-only monitoring
Cost	\$0 (UptimeRobot Free handles all 3 monitors under the 50-monitor limit)

Layer 4 — Security Hardening

Current State

No confirmed 2FA on WP admin accounts. No Wordfence or equivalent file-integrity scanner. No plugin vulnerability review cadence. WooCommerce, Yoast, and custom theme code are updated ad-hoc. PHP 7.4→8.x SiteGround cutover on May 20 increases surface area for plugin incompatibility issues.

Proposed Addition

4a — WordPress 2FA

- Plugin: **WP 2FA** (free, by Melapress)
- Enforce TOTP for all admin-role accounts
- Casey (admin) and Aiden (admin) both need app setup (Google Authenticator / Authy)
- SiteGround also offers 2FA at hosting account level — enable separately

4b — Limit Login Attempts Reloaded (see Layer 2 Part A — same plugin, dual purpose)

4c — Wordfence Free

- Install via WP admin: **Wordfence Security**
- Enable: File Change Detection scan (weekly auto-scan, daily manual on staging)
- Enable: Malware scan on **wp-content/themes/reyco/** + **wp-content/plugins/**
- Disable: Firewall mode (use Cloudflare for that — avoid double-firewall conflicts)
- Alert: Email on detected file change or known-malicious signature

4d — Plugin vulnerability review cadence

- Monthly: Run Wordfence scan + check WPScan Vulnerability Database for installed plugins
- Plugins to watch: WooCommerce, Yoast SEO, Contact Form 7 (if installed), WP All Import (Lightspeed sync)
- Document in monthly retainer check-in with Casey

4e — wp-config.php hardening (already partially done in custom theme, verify)

```
// Verify these are in wp-config.php:
define('DISALLOW_FILE_EDIT', true);      // Disable theme/plugin editor in WP admin
define('DISALLOW_FILE_MODS', true);      // Disable plugin/theme installs from admin (set
define('WP_DEBUG', false);                // Already confirmed off
define('FORCE_SSL_ADMIN', true);          // Force HTTPS on wp-admin
```

Estimated effort	3h (plugin installs, 2FA setup for both admin accounts, wp-config.php audit, Wordfence config, cadence doc)
Risk to live site	Low — <code>DISALLOW_FILE_MODS</code> will block future plugin installs from WP admin (intended); must be removed temporarily for plugin updates. 2FA locks out admin if phone lost — document backup codes.
Cost	\$0 (WP 2FA free, Wordfence Free). Wordfence Premium (\$119 USD/yr) adds real-time threat intelligence feed — not required at current traffic.

Layer 5 — Rollback Runbook

Current State

None documented. Git history exists at `glvcrypto/reyc0-marine` (master branch), so a code rollback is technically possible but no procedure is written. SiteGround GrowBig includes daily automated backups (30-day retention) but the restore procedure is undocumented and untested.

Proposed Rollback Runbook

Reyc0 Marine — Site Rollback Runbook v1 *For use when a deploy breaks production or staging*

Prerequisites:

- SiteGround account access (Aiden)
- GitHub access to `glvcrypto/reyc0-marine` (Aiden or Ben)

- WP admin access at `reycomarine.com/wp-admin` (Aiden)
- SSH access: `giowm1155.siteground.biz:18765` with key `~/.ssh/sg-reyco`

Scenario A — Code change broke the site (theme or plugin)

```
# 1. Identify last known good commit
git log --oneline master | head -20

# 2. Create rollback branch
git checkout -b rollback/emergency-$(date +%Y%m%d)
git reset --hard <last-good-commit-hash>
git push origin rollback/emergency-$(date +%Y%m%d)

# 3. On SiteGround SSH – pull the rollback branch
ssh -p 18765 giowm1155.siteground.biz -i ~/.ssh/sg-reyco
cd ~/public_html # or the reyco vhost path
git fetch origin
git checkout rollback/emergency-$(date +%Y%m%d)

# 4. Verify site is loading
curl -I https://reycomarine.com

# 5. After recovery – open a PR from rollback branch → master to formally revert
```

Scenario B — Database/plugin issue (WP admin accessible)

1. WP Admin → Tools → Export (full export as backup)
2. Plugins → Deactivate the last-installed/updated plugin
3. If site recovers → leave that plugin deactivated, open issue with plugin author
4. If not → proceed to Scenario C

Scenario C — Full SiteGround backup restore

1. Log in at `my.siteground.com`
2. Websites → `reycomarine.com` → Backups
3. Select most recent backup before the incident (daily backups, 30-day retention)
4. Restore to staging first, verify, then restore to production
5. Estimated restore time: 15-30 minutes

Scenario D — PHP 7.4→8.x SiteGround cutover broke something (May 20 risk window)

1. Check SiteGround PHP version: Site Tools → Devs → PHP Manager
2. Temporarily revert PHP version if 8.x option is removed (SiteGround may lock it)

3. Identify breaking plugin via binary search (deactivate half, test, narrow down)
4. Common culprits: older WC extensions, custom PHP theme files using deprecated functions
5. Run PHPCS locally: `phpcs --standard=PHPCompatibility --runtime-set testVersion 8.0 wp-content/themes/reyco/`

Emergency contacts:

- SiteGround support: my.siteground.com/chat (24/7, usually 2-5 min response)
- Aiden: [amglvdigital@pm.me](https://t.me/amglvdigital) / Telegram

Estimated effort	1h (write + test Scenario A end-to-end on staging)
Risk to live site	None — documentation only; test rollback procedure on staging, not production
Cost	\$0

Summary

Layer	Current State	Proposed	Effort	Risk	Cost
1. Error Tracking	None	Sentry Free (PHP + JS SDK)	3h	None	\$0
2. Rate Limiting	SiteGround basic only	Limit Login Attempts plugin (now) + Cloudflare Free (post-launch)	0.5h now / +1.5h post-launch	Near-zero (plugin) / Low (CF DNS)	\$0
3. Uptime Monitoring	None	UptimeRobot (3 monitors)	0.5h	None	\$0
4. Security Hardening	None confirmed	WP 2FA + Wordfence + wp-config.php audit + cadence	3h	Low	\$0
5. Rollback Runbook	None	4-scenario runbook (code/DB/SG backup/PHP8)	1h	None	\$0
Total			~8h		\$0

All items in scope as default build hardening — not a billable add-on.